

Esercizio 5 — Analisi di due casi ANY.RUN

Destinatari: cliente / management · **Obiettivo:** valutare le attività osservate e proporre interventi proporzionati al rischio.

L'analisi si basa sulle schermate di due esecuzioni in sandbox ANY.RUN del 25 agosto 2024. La sandbox è un ambiente separato utilizzato per osservare file e collegamenti potenzialmente pericolosi. I risultati descrivono quanto avvenuto durante queste prove; non dimostrano automaticamente una compromissione dei dispositivi aziendali.

Caso 1 — Eseguitabile associato a Vidar e Lumma

The screenshot displays the ANY.RUN analysis interface. On the left, a Windows 10 desktop environment is visible. On the right, a detailed process list is shown, highlighting the execution of '66bddfcb52736_vidar.exe'. The process list includes the following entries:

PID	Process name	Content
2296	svchost.exe - NetworkService - p - s DnsCache	471 b - binary
6780	66bddfcb52736_vidar.exe	321 KB - executable
6854	RegAsm.exe	193 KB - executable
6872	RegAsm.exe	419 b - binary
6884	RegAsm.exe	407 b - binary
6896	RegAsm.exe	
6908	RegAsm.exe - CFG - DMP	
1568	HCAEHJJKFC.exe - PE	
2572	conhost.exe - 0xffffffff-ForceV1	

The interface also shows network requests and a 'Malicious activity' tracker. A warning message at the bottom states: 'Danger [6340] RegAsm.exe: VIDAR has been detected (YARA)'.

Screenshot 1 — Esecuzione di 66bddfcb52736_vidar.exe in ANY.RUN: verdetto "Malicious activity", tracker Vidar/Lumma, richieste HTTP verso 147.45.44[.]104.

Oggetto analizzato: 66bddfcb52736_vidar.exe · **Ambiente:** Windows 10 64 bit · **Durata visualizzata:** 65 secondi · **Verdetto ANY.RUN:** "Malicious activity" · **Riferimenti:** screenshot 1.

Evidenze e interpretazione

Le schermate mostrano diversi elementi coerenti con un'attività malevola:

- ANY.RUN associa alla prova le etichette **Vidar, Lumma, stealer e loader**.
- È visibile un rilevamento **Vidar tramite YARA**, cioè una regola che riconosce caratteristiche del malware (l'avviso "Danger — [6340] RegAsm.exe: VIDAR has been detected (YARA)").
- Il file iniziale avvia più istanze di **RegAsm.exe**. Una di queste, con PID 6908, effettua due richieste HTTP verso **147.45.44[.]104**, ricevendo contenuti classificati come eseguibili, di circa **321 KB** e **193 KB**.
- Nell'albero dei processi compare anche un ulteriore eseguibile denominato **HCAEHJJKFC.exe**. Il nome, composto da **caratteri casuali**, è di per sé un indicatore sospetto: i malware generano spesso copie di sé stessi con nomi randomici per eludere i controlli basati sul nome file.

- La piattaforma riporta otto segnalazioni nella sezione "Network Threats". Non equivalgono necessariamente a otto malware distinti.

RegAsm.exe è un programma legittimo dell'ambiente Microsoft .NET: il suo nome, da solo, non è sospetto. In questo caso, però, la relazione con il campione, i download e il rilevamento Vidar rendono il suo impiego anomalo (tecnica di "living off the land", in cui un binario di sistema legittimo viene abusato per attività malevole).

Le richieste verso servizi di Microsoft e DigiCert, anch'esse presenti, non devono essere automaticamente considerate malevole: possono essere attività del sistema relative ai certificati. Analogamente, la posizione geografica di un indirizzo IP non identifica l'autore dell'attacco.

Spiegazione

Il comportamento osservato è compatibile con una minaccia che può raccogliere informazioni riservate e introdurre ulteriori programmi dannosi. Uno **stealer** è un malware progettato per sottrarre informazioni, per esempio credenziali o dati di sessione. Un **loader** serve a introdurre ulteriori componenti nella macchina. Per l'azienda, le conseguenze possibili comprendono accessi abusivi agli account, esposizione di dati e ulteriori infezioni.

La presenza dell'etichetta **Lumma** va distinta dal rilevamento **Vidar** esplicitamente visibile: per approfondire il ruolo dei singoli componenti occorre esaminare i relativi eventi del report completo. È però utile notare che **Vidar e Lumma appartengono entrambi alla categoria degli info-stealer**: anche se il rilevamento confermato è Vidar, la natura della minaccia (furto di informazioni) resta la stessa, e questo rafforza — non indebolisce — la valutazione.

Classificazione

Valutazione: attività malevola con alta confidenza; rilevamento valutato come **vero positivo** nel contesto della sandbox. La decisione si basa sulla convergenza di rilevamento YARA, processi correlati e download di eseguibili, non soltanto sul nome del file. Non emergono elementi sufficienti per considerare il rilevamento un falso positivo.

Indicatori di compromissione (IoC)

Indicatori raccolti durante la prova, da riverificare prima di un eventuale blocco (risalgono al 2024):

Tipo	Valore	Note
Nome file	66bddfcb52736_vidar.exe	Campione iniziale
Processo abusato	RegAsm.exe (PID 6908)	Binario .NET legittimo usato per i download
File droppato	HCAEHJJKFC.exe	Nome randomico
IP / URL	147.45.44[.]104 (/prog/...)	Sorgente dei due eseguibili scaricati
Famiglia	Vidar (confermata YARA), Lumma (etichetta)	Info-stealer / loader

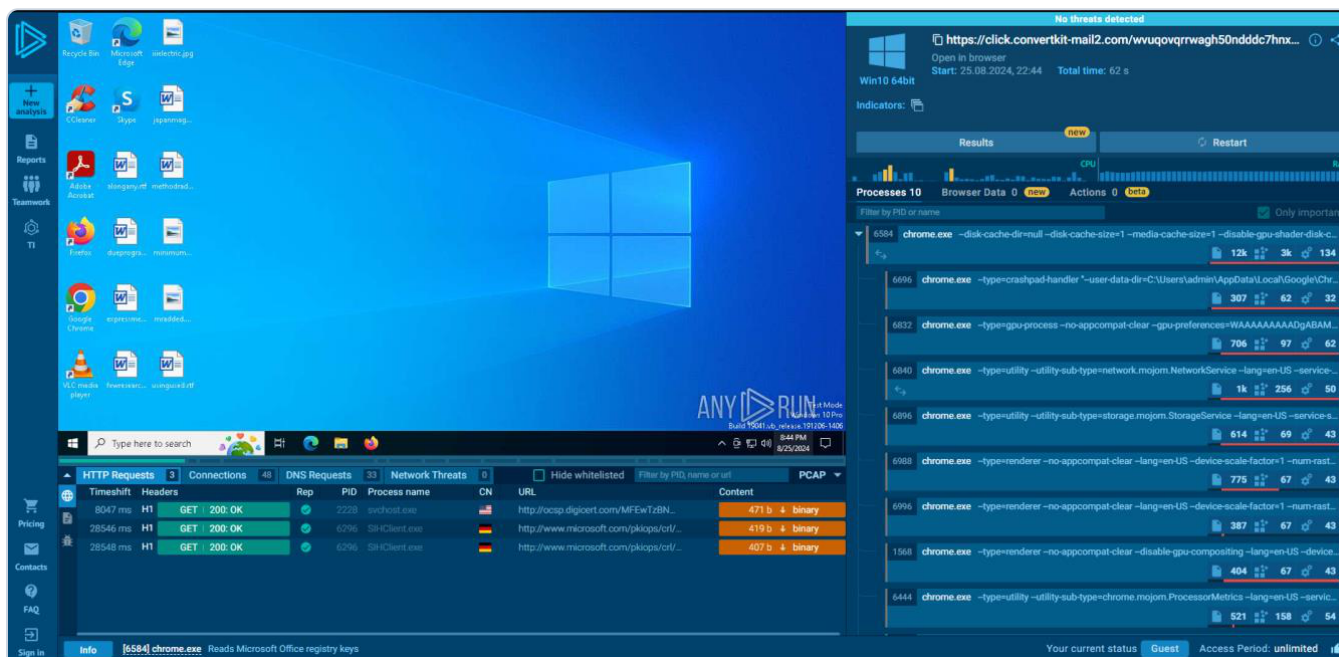
Remediation proposta

Intervento	Motivazione
Quarantena del file	Impedire nuove esecuzioni, conservando una copia controllata per l'analisi.
Verifica dell'esecuzione sui dispositivi aziendali	La semplice presenza del file non dimostra che sia stato avviato. Cercare riscontri nei log antivirus/EDR (i sistemi di protezione e monitoraggio delle postazioni).
Isolamento delle postazioni con esecuzione confermata	Limitare ulteriori comunicazioni e attività dannose, mantenendo quando possibile il canale di gestione della sicurezza.
Conservazione delle evidenze	Raccogliere hash, processi, connessioni e log prima della rimozione, per ricostruire l'accaduto.
Blocco mirato degli indicatori confermati	Bloccare il file tramite hash e valutare gli indirizzi/URL coinvolti. Gli indicatori risalgono al 2024: un blocco attuale richiede una verifica, perché gli IP possono cambiare utilizzo.
Protezione degli account potenzialmente esposti	Se l'esecuzione è confermata, valutare revoca delle sessioni, cambio delle credenziali da un dispositivo pulito e controllo degli accessi anomali.
Bonifica o reinstallazione da immagine affidabile	La sola eliminazione del file iniziale potrebbe lasciare altri componenti. Preferire la reinstallazione quando non è possibile garantire una bonifica completa.

Ulteriori azioni operative: **Eliminazione** — rimuovere il campione e gli eventuali componenti associati dopo aver preservato le evidenze (la cancellazione del solo file iniziale non garantisce la bonifica). **Blacklist** — bloccare gli hash dei campioni confermati tramite gli strumenti di protezione delle postazioni; applicare eventuali blocchi di IP e URL tramite firewall, proxy o gateway, dopo aver verificato gli indicatori e valutato l'impatto sui servizi legittimi. Il **coinvolgimento del vendor** è opportuno se la protezione aziendale non rileva il campione, se i risultati sono discordanti o se servono indicazioni specifiche di rimozione; non deve però ritardare il contenimento di una compromissione confermata.

Conclusione. Il caso richiede un intervento prioritario se viene riscontrato sui sistemi aziendali. La chiusura richiede verifica della bonifica, controllo degli account eventualmente esposti e assenza di ulteriori indicatori durante il monitoraggio.

Caso 2 — Collegamento con navigazione verso Instagram e Facebook



Screenshot 2 — Esecuzione dell'URL `click.convertkit-mail2[.]com` in ANY.RUN: verdetto "No threats detected", processi `chrome.exe`, nessuna Network Threat.

Oggetto analizzato: URL sul dominio `click.convertkit-mail2[.]com` · **Ambiente:** Windows 10 64 bit · **Durata visualizzata:** 62 secondi · **Verdetto ANY.RUN:** "No threats detected" · **Riferimenti:** screenshot 2.

Evidenze e interpretazione

Il secondo caso riguarda un collegamento web, non un eseguibile. Le schermate mostrano:

- Una pagina di accesso che **appare** come `instagram.com`, con un parametro che rimanda a un profilo Instagram.
- Successivamente, una pagina di accesso che **appare** come `facebook.com`.
- Processi `chrome.exe` con funzioni coerenti con il normale funzionamento del browser (gestione della rete e rendering delle pagine).
- Zero segnalazioni nella sezione "Network Threats".
- Alcune richieste HTTP visibili verso Microsoft e DigiCert, senza download di eseguibili mostrati in quella tabella.

Un elemento di contesto va evidenziato: il dominio di partenza `click.convertkit-mail2[.]com` è un **servizio di tracciamento di link per email marketing**. Un link di tracciamento contenuto in un'email che conduce a **pagine di login di Instagram e poi di Facebook** è uno schema che ricorre frequentemente nelle campagne di phishing. Questo non prova che si tratti di phishing, ma alza il livello di sospetto e va considerato nell'analisi.

Cautela sui domini. Gli screenshot mostrano quelli che *appaiono* come i domini legittimi `instagram.com` e `facebook.com`, elemento a favore rispetto a una pagina imitativa. Tuttavia, senza la verifica dell'URL completo nella barra degli indirizzi non è possibile escludere un dominio ingannevole (es. `instagram.com.login-xyz[.]net`) o una pagina sovrapposta. L'apparenza del dominio, da sola, non è una prova di autenticità.

Il passaggio **Instagram** → **Facebook** ammette due letture alternative, da tenere entrambe aperte: (a) interazione legittima con il pulsante "Log in with Facebook" presente nella pagina Instagram; oppure (b)

reindirizzamento all'interno di un flusso di phishing multi-piattaforma. Gli screenshot documentano le destinazioni ma non l'intera sequenza di navigazione.

La voce "Reads Microsoft Office registry keys" è classificata come informativa. Una lettura del registro, isolatamente, non prova attività malevola; inoltre, trattandosi qui di una navigazione in Chrome, è un comportamento di sistema non necessariamente collegato al collegamento analizzato e non va sovrainterpretato. Analogamente, la dicitura "binary" non significa "malware": descrive il formato del contenuto.

Spiegazione

Durante la prova non sono emerse evidenze tecniche sufficienti a classificare il collegamento come malware, e il verdetto automatico della sandbox è "No threats detected". Tuttavia, **il contesto d'uso — un link di tracciamento email che apre form di login social — è compatibile anche con uno scenario di phishing / raccolta credenziali**, che deve essere trattato come ipotesi di pari rilievo rispetto a quella benigna finché non si verifica l'URL completo e l'intera catena di navigazione.

Un motivo tecnico per cui la sandbox potrebbe non aver rilevato nulla è che il phishing richiede **interazione umana** (l'inserimento effettivo delle credenziali), che in 62 secondi di esecuzione automatica non avviene: l'assenza di detection non equivale quindi ad assenza di rischio. La presenza di una pagina di login non indica, da sola, un tentativo di furto credenziali, ma nemmeno lo esclude.

Classificazione

Valutazione: nessuna minaccia rilevata dalla sandbox; comportamento tecnicamente non malevolo nella prova, ma con **confidenza bassa** sulla natura benigna, a causa del contesto (link email → login social) non verificato.

Il risultato è **compatibile** con un vero negativo, ma **non confermabile come tale** senza verificare il contesto del collegamento e l'intera navigazione. Non è comunque corretto definirlo automaticamente:

- **Falso positivo:** servirebbe una segnalazione di minaccia poi dimostrata errata (qui non c'è segnalazione).
- **Falso negativo:** servirebbero evidenze di una minaccia reale sfuggita al controllo — plausibile in questo scenario, quindi da escludere solo dopo verifica.

Remediation proposta

Intervento	Motivazione
Nessuna bonifica o isolamento sulla sola base degli screenshot	Non sono mostrate evidenze di compromissione che giustifichino queste azioni.
Verifica del messaggio e del mittente	Controllare che il collegamento fosse atteso e coerente con il contenuto ricevuto (priorità alta, dato il vettore email).
Verifica dell'URL completo e della catena di navigazione	Accertare il dominio reale delle pagine di login e gli eventuali passaggi intermedi, download e destinazioni effettive tramite report e log disponibili.
Nessuna blacklist generalizzata	Bloccare interamente Instagram, Facebook o il servizio di collegamenti sarebbe sproporzionato rispetto alle evidenze.
Quarantena temporanea del singolo messaggio, se esistono altri sospetti	Misura reversibile in attesa di chiarimenti su mittente o contenuto, non conseguenza automatica del risultato della sandbox.
Richiesta al vendor solo in caso di incongruenze	Utile se il sistema aziendale segnala phishing o malware mentre questa prova non mostra elementi corrispondenti.

Non è necessario cambiare password soltanto perché è stata visualizzata una pagina di accesso. L'intervento sugli account diventa necessario se emergono prove di credenziali inviate a una destinazione fraudolenta o di accessi non autorizzati.

Conclusione. Le evidenze tecniche disponibili non giustificano la classificazione del collegamento come minaccia confermata, ma il contesto (link di tracciamento email verso form di login social) non consente nemmeno di chiuderlo con sicurezza come benigno. Si propone una verifica del contesto e dell'URL completo; solo se coerente, la chiusura come attività benigna, documentando i limiti della prova.

Glossario (valido per entrambi i casi)

Termine	Spiegazione semplice
PID	Numero che identifica un programma in esecuzione.
HTTP	Protocollo utilizzato per scambiare risorse web.
Hash	Impronta digitale del contenuto di un file, utile per identificarlo.
YARA	Regola che riconosce un malware in base a caratteristiche note del suo contenuto.
Stealer / Loader	Malware che ruba informazioni / malware che scarica e installa altri componenti.
Vendor	Fornitore del prodotto di sicurezza.
Revoca delle sessioni	Invalidazione degli accessi già attivi agli account.

Confronto finale

Caso	Valutazione	Decisione principale
1 — Eseguitibile	Attività malevola; vero positivo nella sandbox	Quarantena e verifica dell'esecuzione; isolamento e recupero delle postazioni compromesse.
2 — Collegamento	Nessuna minaccia rilevata dalla sandbox; benigno con confidenza bassa (contesto da verificare)	Verifiche contestuali e dell'URL completo, senza blocchi generalizzati o bonifiche ingiustificate.

Le classificazioni descrivono l'esito dell'analisi; quarantena, eliminazione e blacklist sono invece azioni operative, da scegliere in base alle evidenze e all'effettiva esposizione aziendale.